INTRODUCTION

API Security Risk Analysis Report – Task 3
Target API: JSONPlaceholder

(https://jsonplaceholder.typicode.com)
Prepared by: Rajat Kumar

1. Introduction

   What is an API?

   An Application Programming Interface (API) is a contract that enables software components to communicate by exposing standardized endpoints and data formats. Modern SaaS platforms depend heavily on APIs to connect microservices, mobile/web clients, and third-party integrations. Securing these interfaces is therefore critical to preserving the **confidentiality, integrity, and availability** of data and services.

2. **Why API Security matters for SaaS**

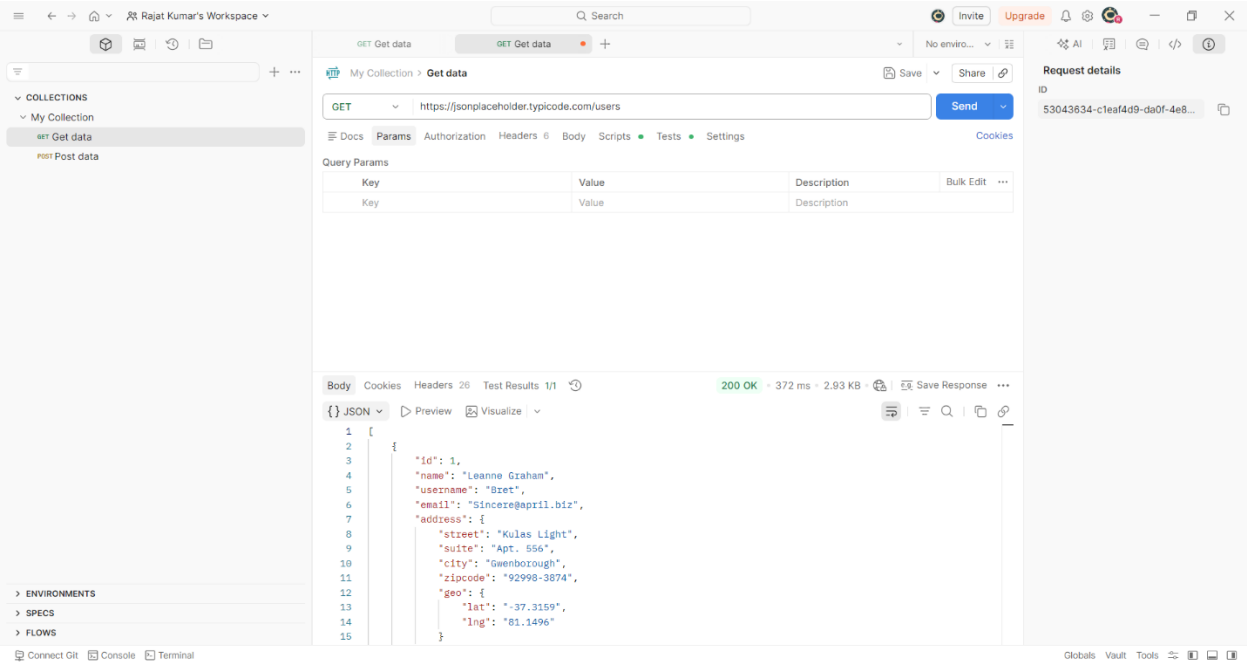
   APIs are often the most exposed surface of a SaaS product. Without robust controls (authentication, authorization, data minimization, and rate limiting), attackers can abuse APIs to extract data, disrupt services (DoS), or impersonate users, causing operational downtime, regulatory exposure, and reputational harm.

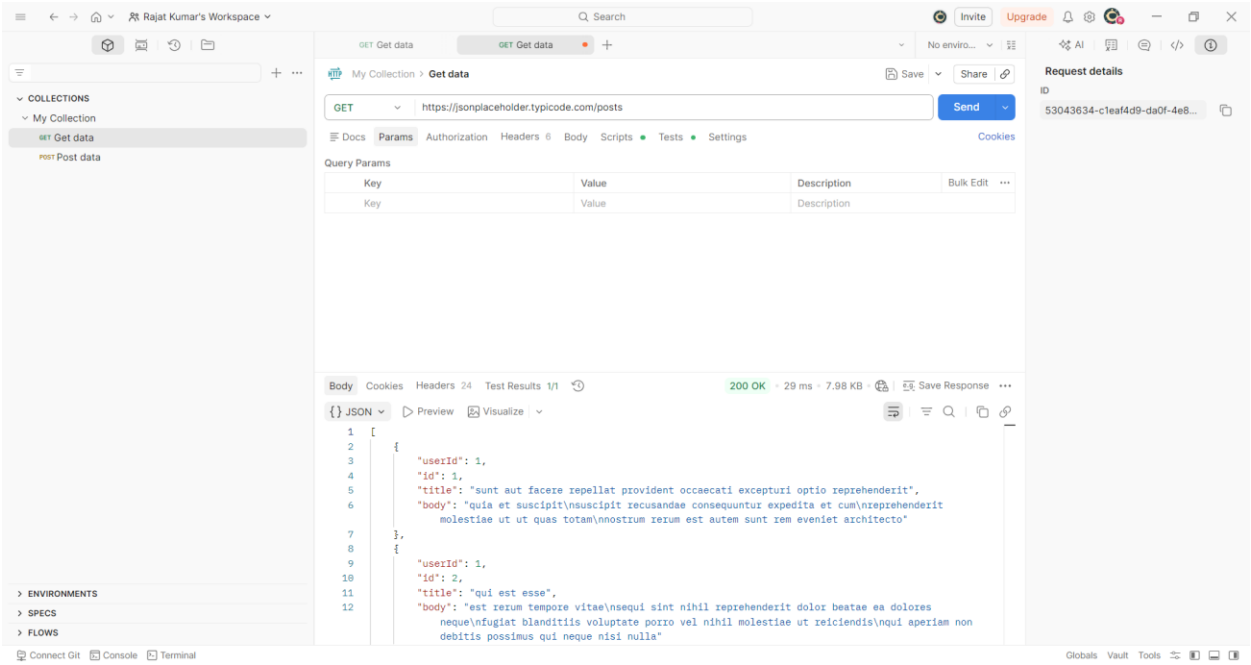
2. API Overview

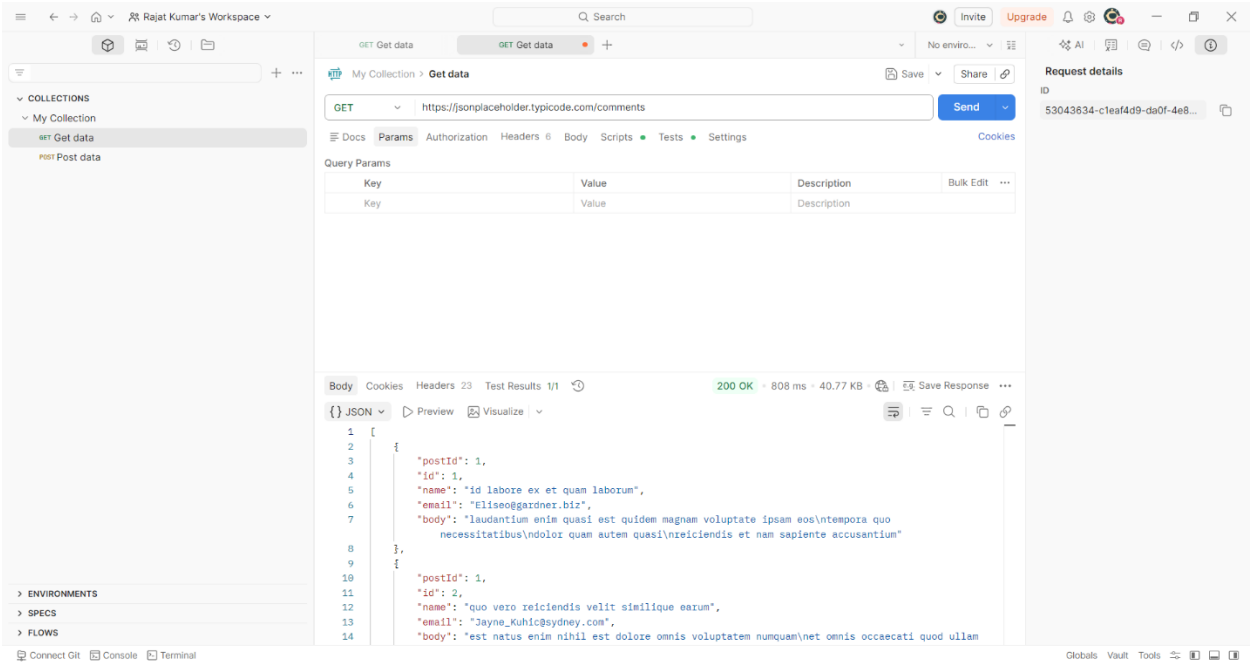
API Under Test: JSONPlaceholder – a free, public, fake REST API commonly used for testing and prototyping. It provides six core resources, including **/users**, **/posts**, and **/comments**, and supports standard HTTP methods. For this task, the analysis focused on the following read endpoints:

- GET /users
- GET /posts
- GET /comments

SCREENSHOTS OF API Testing




Rajat Kumar's Workspace
Search
Invite
Upgrade
GET Get data
GET Get data
No enviro...
AI
COLLECTIONS
My Collection
GET Get data
POST Post data
My Collection > Get data
Save
Share
Request details
ID
53043634-c1eaf4d9-da0f-4e8...
GET
https://jsonplaceholder.typicode.com/posts
Send
Docs
Params
Authorization
Headers 6
Body
Scripts
Tests
Settings
Cookies
Query Params
Key
Value
Description
Bulk Edit
Key
Value
Description
Body
Cookies
Headers 24
Test Results 1/1
200 OK
29 ms
7.98 KB
Save Response
JSON
Preview
Visualize
[
{
"userId": 1,
"id": 1,
"title": "sunt aut facere repellat provident occaecati excepturi optio reprehenderit",
"body": "quia et suscipit\nsuscipit recusandae consequuntur expedita et cum\nreprehenderit molestiae ut ut quas totam\nnostrum rerum est autem sunt rem eveniet architecto"
},
{
"userId": 1,
"id": 2,
"title": "qui est esse",
"body": "est rerum tempore vitae\nsequi sint nihil reprehenderit dolor beatae ea dolores neque\nfugiat blanditiis voluptate porro vel nihil molestiae ut reiciendis\nqui aperiam non debitis possimus qui neque nisi nulla"
ENVIRONMENTS
SPECS
FLOWS
Connect Git
Console
Terminal
Globals
Vault
Tools


Rajat Kumar's Workspace
Search
Invite
Upgrade
COLLECTIONS
My Collection
GET Get data
POST Post data
ENVIRONMENTS
SPECS
FLOWS
GET Get data
GET Get data
No enviro...
My Collection > Get data
Save
Share
GET
https://jsonplaceholder.typicode.com/comments
Send
Docs
Params
Authorization
Headers 6
Body
Scripts
Tests
Settings
Cookies
Query Params
Key
Value
Description
Bulk Edit
Key
Value
Description
Body
Cookies
Headers 23
Test Results 1/1
200 OK
808 ms
40.77 KB
Save Response
JSON
Preview
Visualize
[
{
"postId": 1,
"id": 1,
"name": "id labore ex et quam laborum",
"email": "Eliseo@gardner.biz",
"body": "laudantium enim quasi est quidem magnam voluptate ipsam eos\ntempora quo necessitatibus\ndolor quam autem quasi\nreiciendis et nam sapiente accusantium"
},
{
"postId": 1,
"id": 2,
"name": "quo vero reiciendis velit similique earum",
"email": "Jayne_Kuhic@sydney.com",
"body": "est natus enim nihil est dolore omnis voluptatem numquam\net omnis occaecati quod ullam
AI
Request details
ID
53043634-c1eaf4d9-da0f-4e8...
Connect Git
Console
Terminal
Globals
Vault
Tools

4. Security Risks Identified

4.1 Unauthenticated Access — Severity: Medium

Observation: The endpoints are publicly accessible without API keys or tokens. While this is expected for a demo service, mirroring this pattern in production would raise the risk of unauthorized data access and automated abuse.

why it matters: APIs without authentication invite scraping, enumeration, and targeted attacks. In real systems, missing or weak authentication is associated with account takeover and data exposure.

4.2 Excessive Data Exposure — Severity: Low

Observation: GET /users returns full user profiles including nested address objects with **geolocation** (geo.lat, geo.lng). In a production context, returning fields beyond the client’s need increases exposure surface and can conflict with data-minimization principles.

4.3 Lack of Rate Limiting — Severity: Medium

Observation: The JSONPlaceholder documentation (newer domain) explicitly notes **no rate limits** for the public API. In production, absence of throttling enables **automated abuse** (e.g., scripted scraping) and increases the risk of **application-layer DoS**.

Why it matters: Rate limiting and throttling are standard defenses to preserve availability and resist brute force or volumetric request bursts at the API layer.

5. Risk Severity Table

Risk	Severity	Business Impact (If this were a production SaaS)
Unauthenticated Access	Medium	Uncontrolled public access to data; enables scraping, enumeration, and abuse; may violate compliance if PII is exposed. [practical-...secops.com]
Excessive Data Exposure	Low	Over-disclosure of fields (e.g., geolocation) increases privacy and legal risk; attackers see more context than necessary. [owasp.org]
Lack of Rate Limiting	Medium	Facilitates automation, credential-stuffing attempts, and can degrade or deny service under load (App-layer DoS). hackerone+1

6. Remediation Suggestions

1. **Introduce Authentication & Authorization**
   - Require **JWT-based** authentication (e.g., OAuth 2.0 access tokens) for non-public endpoints; validate
   - expiry; scope claims per endpoint. [owasp.org]
   - Apply **least-privilege** authorization checks (e.g., user-/tenant-scoped access). [owasp.org]
2. **Data Minimization to Prevent Excessive Exposure**
   - Implement **server-side field filtering** (response shaping) so only required properties are returned; avoid generic object serialization that leaks nested fields. [owasp.org]
   - Classify PII and sensitive attributes; review all responses against that inventory. [owasp.org]
3. **Rate Limiting & Abuse Prevention**

- Enforce **per-IP / per-token** rate limits using token-bucket or sliding-window algorithms; return 429 Too Many Requests with Retry-After. [hackerone.com]
- Add **burst control** and **circuit breakers** at the edge (WAF/API Gateway) to mitigate scraping and app-layer DoS. [cheatsheet....owasp.org]

4. **API Gateway Controls**

- Place endpoints behind an **API Gateway** to centralize authentication, throttling, request/response validation, CORS policy, and logging. [c-sharpcorner.com]

7. Ethical Consideration

This assessment was strictly read-only and educational. It used publicly documented demo endpoints, limited to safe GET requests in Postman, with no exploitation, bypass attempts, or performance/DoS testing performed.

8. Conclusion

APIs are the backbone of modern SaaS and, if under-secured, become a primary path to data loss and downtime. Even in a benign demo API like JSONPlaceholder, the patterns of open access, broad responses, and no throttling illustrate how production APIs can drift into risky territory without intentional security design. Implementing strong auth (JWT/OAuth2), server-side data minimization, and defensive rate limiting at an API gateway provides a practical baseline that materially reduces risk and improves resilience.

Appendix A — Postman Evidence Placeholders

- **A1: GET /users — Response body (highlight address.geo).**
- **A2: GET /posts — Response list (status 200, headers).**
- **A3: GET /comments — Filtered query example (e.g., ?postId=1).**
- **A4: Collection Runner screenshot (for illustrating request bursts).**

References

- JSONPlaceholder (official): Overview, resources, and routes. [jsonplaceh...picode.com]
- JSONPlaceholder (new docs): API reference, resources, and statement about no rate limits. [jsonplaceholder.dev], [jsonplaceholder.dev]
- OWASP API Security Top 10 — Excessive Data Exposure (API3:2019): definition and prevention. [owasp.org]
- OWASP Cheat Sheet — Denial of Service: context for availability risks and mitigations. [cheatsheet....owasp.org]

- **HackerOne Blog — Rate Limiting strategies against DDoS & brute force. [hackerone.com]**
- **Practical DevSecOps — Risks of unauthenticated APIs. [practical-...secops.com]**
- **Postman API Network — JSONPlaceholder collection (tooling reference).**